MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 067 · OCTOBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

WALK-THROUGH · PHYSICAL PROTECTION

Physical Access Is 13 SPRS Points No Small Shop Can Put on a POA&M

NIST 800-171 physical protection, 3.10.1 to 3.10.5, carries 13 SPRS points and none can wait on a POA&M. A walk through a small shop, door by door.

BY **MAXINE** READING TIME · 5 MIN PHYSICAL-PROTECTION · NIST-800-171 · SPRS · POAM · CMMC

Physical protection is the part of NIST SP 800-171 that a small defense contractor hands to whoever holds the office keys, and it is the part where the assessment offers no second chance. Requirements 3.10.1 through 3.10.5 carry 13 points under the DoD Assessment Methodology, two of them at 5 points and three at 1, and not one of the five can sit on a Level 2 POA&M. The two heavy ones exceed the 1-point ceiling, and the three light ones are named exclusions. The POA&M rules themselves ran in an earlier issue. This one is about what they mean for a building.

An assessor tests this family largely on foot. The NIST SP 800-171A methods for it read like a facilities tour: examine the authorized personnel access list, the physical access logs and their reviews, the inventory of physical access control devices, the records of key and lock combination changes, the system entry and exit points; interview the people who hold physical access responsibilities; test the mechanisms that enforce it. The useful rehearsal is that same walk, taken first, by someone carrying the system security plan. Take a small shop in a leased suite, a dozen people with one front door and one locked closet holding the server and the switch, and walk it from the outside in.

FIELD COPY
ISSUE Nº 067
PHYSICAL
PROTECTION

13

SPRS POINTS ACROSS 3.10.1 TO 3.10.5, TWO REQUIREMENTS AT 5 AND THREE AT 1

14

ASSESSMENT OBJECTIVES ACROSS THOSE FIVE REQUIREMENTS, AND ONE UNMET OBJECTIVE COSTS THE REQUIREMENT ITS FULL WEIGHT

0

OF THE FIVE THAT A LEVEL 2 POA&M MAY CARRY UNDER 32 CFR 170.21(A)(2)

The front door, and the list it should match

Requirement 3.10.1 is worth 5 points and asks four things. The first is a list: the individuals allowed physical access are identified (3.10.1[a]). The other three ask that access be limited to those individuals at three levels, the systems, the equipment, and the operating environments. The assessor's examine list adds physical access list reviews and physical access termination records, which means the list is expected to change when someone leaves and to be checked when nobody does.

The common failure is not an unlocked door. It is a door locked against everyone except a population nobody wrote down: the landlord's maintenance staff, the cleaning contractor, the former office manager whose code still works. Each is an authorized individual in practice and absent from the list on paper, and 3.10.1[a] is scored on the paper. One unmet objective costs the requirement all 5 points.

The ring of keys, and the code that never changed

Requirement 3.10.5 is worth 1 point and asks that physical access devices be identified, controlled, and managed (3.10.5[a] to [c]). Devices means keys, badges, fobs, and combinations. Here the examine list is unusually concrete: inventory records of physical access control devices, the storage locations for them, and records of key and lock combination changes. In a small shop the inventory is usually a desk drawer. Identified means someone can say how many keys to the closet exist and who holds each one. Controlled means the spares are not on a hook by the door. Managed means the combination changes when a person who knew it leaves, and a record shows that it did.

This is the requirement most likely to be met in practice and unmet on paper, and because 3.10.5 is one of the named exclusions, a shop cannot carry it as a gap and close it afterward. It is met on assessment day or it costs the point.

The visitor, from sign-in to sign-out

The visitor is where two 1-point requirements meet. Requirement 3.10.3 asks that visitors be escorted and their activity monitored. Requirement 3.10.4 asks, in a single objective, that audit logs of physical access be maintained. A sign-in sheet at the front desk with a name, a time in, a time out, and the host's initials can serve both, provided the escort is real. A visitor who signs in and is then left alone in the conference room beside the closet while the host takes a call has been logged and not escorted.

The sign-in sheet answers a 1-point requirement. Someone reading it answers part of a 5-point one.

The sheet carries more weight than its own score suggests. Requirement 3.10.2 asks, among other things, that the physical facility be monitored (3.10.2[c]), and the examine list for 3.10.2 names physical access logs, physical access monitoring records, and physical access log reviews. A log that is kept and never read satisfies the maintenance objective of 3.10.4 and leaves 3.10.2 without the review its examine list names. A dated, initialed review on a fixed schedule, with anything odd written down, is a small discipline. If an assessor reads its absence as an unmonitored facility, the cost is 3.10.2's full 5 points.

◆ THE ONE 3.10 REQUIREMENT THAT CAN WAIT

Requirement 3.10.6, safeguarding CUI at alternate work sites, is worth 1 point and is not among the six requirements 32 CFR 170.21 names as excluded, so it is the only requirement in the family a Level 2 POA&M can carry. MacZine covered what it means for a residence in its issue on the home office.

The closet, and what keeps it running

Requirement 3.10.2 has the widest reach of the five, because its objectives name two things and ask two questions of each: the physical facility where the system resides and the support infrastructure for that system, each protected and each monitored (3.10.2[a] to [d]). The facility is the suite and the closet. The support infrastructure is the half shops skip. A reasonable reading for a small office is whatever the server and switch depend on to run: the power feed, the cooling, the point where the carrier's line enters the building. In a leased suite some of that sits in a shared utility room the shop does not control. That is not a failure in itself. It is a fact the system security plan should state, together with what the shop does about it, whether a lease term, the landlord's access record for that room, or a locked cabinet inside it.

The closet also settles the third level of 3.10.1, the operating environment. A server behind a door code the whole staff knows has its physical access limited to authorized individuals only if the whole staff is authorized for that closet. The honest answer is usually a shorter list for the closet than for the front door, and the separate objectives for systems, equipment, and operating environments leave room for exactly that.

By the time the walk reaches the closet, it has produced five things, none of them technical: a roster for the front door, a shorter one for the closet, an inventory of keys and codes with its change record, a visitor log, and a dated review of that log, plus a paragraph in the plan about the utility room. A program that wants a second pair of eyes on the rest of its Level 2 boundary can start at /readiness. For these five requirements, though, the regulation leaves no later date to fix them by, and the assessor will ask to open the desk drawer. It should hold a list. ◆